

- An explanation that while the institution may contact a customer regarding his or her account or suspicious activities related to his or her account, the institution should never ask the customer to provide his or her log-in credentials over the phone or via e-mail.
- A list of recommended controls and prudent practices that the customer should implement when using the institution's remote financial services.
- A suggestion that commercial online customers perform a related risk assessment and controls evaluation periodically.
- Recommendations of technical and business controls to commercial customers that can be implemented to mitigate the risks from fraud schemes such as Business Email Compromise.⁴⁹
- A method to contact the institution if customers notice suspicious account activity.

II.C.17 Application Security

Action Summary

Management should use applications that have been developed following secure development practices and that meet a prudent level of security. Management should develop security control requirements for all applications, whether the institution acquires or develops them. Information security personnel should be involved in monitoring the application development process to verify that secure development practices are followed, security controls are implemented, and information security needs are met.

Institutions and their customers use a wide variety of applications. Such applications include core banking applications, web applications, and installable applications (e.g., downloadable mobile applications).

A secure software development life cycle ensures that Internet- and client-facing applications have the necessary security controls. The institution should ensure that all applications are securely developed. To verify the controls have been developed and implemented appropriately, management should perform appropriate tests (e.g., penetration tests, vulnerability assessments, and application security tests) before launching or making significant changes to external-facing applications. Issues noted from tests should be remediated before launching applications or moving changes into production. At institutions that employ third parties to develop applications, management should ensure that the third parties meet the same controls.

Applications should provide the ability for management to do the following:

- Implement a prudent set of security controls (e.g., password and audit policies), audit trails of security and access changes, and user activity logs for all applications.
- Establish user and group profiles for applications if not part of a centralized identity access management system.

⁴⁹ See Federal Bureau of Investigation, [Alert I-012215-PSA](#).

- Change and disable default application accounts upon installation.
- Review and install patches for applications in a timely manner.
- Implement validation controls for data entry⁵⁰ and data processing.⁵¹
- Integrate additional authentication and encryption controls, as necessary, to ensure integrity and confidentiality of data and non-repudiation of transactions.
- Protect web or Internet-facing applications through additional controls, including web application firewalls, regular scanning for new or recurring vulnerabilities, mitigation or remediation of common security weaknesses, and network segregation to limit inappropriate access or connections to the application or other areas of the network.
- Mitigate risks from potential flaws in applications allowing remote access by customers and others through network, host, and application layer architecture considerations.
- Obtain attestation or evidence from third-party developers that the application acquired by the institution meets the necessary security requirements and that noted vulnerabilities or flaws are remediated in a timely manner.
- Perform ongoing risk assessments to consider the adequacy of application-level controls in light of changing threat, network, and host environments.
- Implement minimum controls recommended by the third-party service provider and consider supplemental controls as appropriate.
- Review available audit reports, and consider and implement appropriate control recommendations
- Collect data to build metrics and reporting of configuration management compliance, vulnerability management, and other measurable items as determined by management.

Whether the institution acquires or develops applications, management should establish security control requirements for new systems, system revisions, or new system acquisitions. Management should define the security control requirements based on its risk assessment process and evaluate the value of the information at risk and the potential impact of unauthorized access or damage within existing software development and acquisition processes. Management should have a process to determine risks posed by the system and necessary security requirements. Management may also refer to published, widely recognized industry standards as a starting point for establishing the institution's security requirements.

Information security personnel should be involved from the outset in the application development process to determine whether security controls are designed, tested, and implemented and information security needs are being met. Monitoring the development environment can help ensure that the implemented controls are functioning properly. Institutions that purchase applications typically rely on third-party service providers to develop applications with appropriate security built-in; management, however, should perform its own verification to

⁵⁰ Data entry validation controls include access controls over entry and changes to data, error checks, review of suspicious or unusual data, and dual entry or additional review and authorization for highly sensitive transactions or data.

⁵¹ Data processing controls include batch control totals, hash totals of data for comparison after processing, identification of any changes made to data outside the application (e.g., data-altering utilities), and job control checks to ensure programs run in correct sequence.

determine whether the application meets the institution's security requirements. Management should analyze the environment where the application will reside. As the environment changes, the security requirements and assurance needs for the application may also change. Management should leverage available resources⁵² to assist in risk identification and improve the institution's application security practices.

II.C.18 Database Security

Action Summary

Management should implement effective controls for databases and restrict access appropriately.

Databases are collections of information organized to be easily accessed, managed, and updated. Databases can be developed in-house or purchased from third parties and have their own controls and protective mechanisms configured to provide varying levels of protection. Along with many other security features, encryption helps to protect the stored information from theft or unauthorized viewing. Management should implement or enable controls commensurate with the sensitivity of the data stored in or accessed by the database.

Database users may be people (e.g., employees, customers, and contractors) or other applications. Users have different levels of access and authorization. Some users may have extensive privileges, including the ability to change the database configuration and access controls. Other users may have restrictions in what they can view, manipulate, or store. When a person is the database user, authorizations can be tailored to that person, greatly limiting the amount of information that could be exposed in a security incident. When an application is the database user, the access granted to the application can be more extensive than a person would require. Accordingly, an attack on a database through an application could expose a larger and more damaging collection of data. For application accounts, management should strengthen authentication and monitoring requirements to minimize the potential for unauthorized use.

Management should appropriately control user access and apply the principle of least privilege in assigning authorizations. The use and overall configuration of a database's security features should be part of a well-designed, layered security program.

II.C.19 Encryption

Action Summary

Management should implement the type and level of encryption commensurate with the sensitivity of the information.

⁵² Resources include software tools, industry resources, specific certifications, and education courses.

Encryption is used to secure communications and data storage, particularly authentication credentials and the transmission of sensitive information. Encryption can be used throughout a technological environment, including the operating systems, middleware, applications, file systems, and communications protocols.

Encryption can be used as a preventive control, a detective control, or both. As a preventive control, encryption acts to protect data from disclosure to unauthorized parties. As a detective control, encryption is used to allow management to discover unauthorized changes to data. When prevention and detection are joined, encryption can be an important control in ensuring confidentiality, integrity, and availability.

Institution management should employ encryption strength sufficient to protect information from disclosure. Encryption methods should be reviewed periodically to ensure that the types and methods of encryption are still secure as technology and threats evolve. Decisions regarding what data to encrypt and at what points to encrypt the data are typically based on the risk of disclosure and the costs of encryption. The need to encrypt data is determined by the institution's data classification and risk assessment.

Passwords should be hashed or encrypted in storage. Passwords that are hashed also should be salted.⁵³ Files containing encrypted or hashed passwords used by systems to authenticate users should be readable only with elevated (or administrator) privileges.

Key management⁵⁴ is crucial to the effective use of encryption. Effective key management systems rely on an agreed set of standards, procedures, and secure methods that address the following:⁵⁵

- Generating keys for different cryptographic systems and different applications.
- Generating and obtaining public keys.
- Distributing keys to intended users, including how keys should be activated when received.
- Storing keys, including how authorized users obtain access to keys.
- Changing or updating keys, including rules on when and how keys should be changed.
- Addressing compromised keys.
- Archiving, revoking, and specifying how keys should be withdrawn or deactivated.
- Recovering keys that are lost or corrupted as part of business continuity management.
- Logging the auditing of key management-related activities.
- Instituting defined activation and deactivation dates, and limiting the usage period of keys.

⁵³ In password protection, salt is a random string of data used to modify a password hash.

⁵⁴ Key management is the management of cryptographic keys. This includes dealing with the generation, exchange, storage, use, and replacement of keys.

⁵⁵ Refer to ISO/IEC 11770-1:2010, "Key Management—Part 1: Framework"; ISO/IEC 11770-2:2008, "Key Management—Part 2: Mechanisms Using Symmetric Techniques"; and ISO/IEC 11770-3:2015, "Key Management—Part 3: Mechanisms Using Asymmetric Techniques."

II.C.20 Oversight of Third-Party Service Providers

Action Summary

Management should oversee outsourced operations through the following:

- Appropriate due diligence in third-party research, selection, and relationship management.
- Contractual assurances for security responsibilities, controls, and reporting.
- Nondisclosure agreements regarding the institution's systems and data.
- Independent review of the third party's security through appropriate reports from audits and tests.
- Coordination of incident response policies and contractual notification requirements.
- Verification that information and cybersecurity risks are appropriately identified, measured, mitigated, monitored, and reported.

Management should conduct appropriate due diligence in selecting and monitoring third-party service providers. Management should be responsible for ensuring that such third parties use suitable information security controls when providing services to the institution. When indicated by the institution's risk assessment, management should monitor third-party service providers to confirm that they are maintaining appropriate controls. If the third-party service provider stores, transmits, processes, or disposes of customer information, management should require third-party service providers by contract to implement appropriate measures designed to meet the Information Security Standards.

Management should evaluate information security considerations of potential third-party service providers during initial due diligence. Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for more information.

Management should verify that third-party service providers implement and maintain controls sufficient to appropriately mitigate risks. The institution's contracts should do the following:

- Include minimum control and reporting standards.
- Provide for the right to require changes to standards as external and internal environments change.
- Specify that the institution or an independent auditor has access to the service provider to perform evaluations of the service provider's performance against the Information Security Standards.

Refer to the "Third-Party Reviews of Technology Service Providers" section of the *IT Handbook's* "Audit" booklet for more information.

Additionally, as part of the oversight of third-party service providers, management should determine whether cyber risks are identified, measured, mitigated, monitored, and reported by such third parties as third-party cyber threats can have an impact on the institution. Information security reporting by the institution should incorporate an assessment of these third-party risks to

facilitate a comprehensive understanding of the institution's exposure to third-party cyber threats.

II.C.20(a) *Outsourced Cloud Computing*

As with other forms of outsourcing, information security implications are key in the cloud computing model. Management may need to revise information security policies, standards, and procedures to incorporate the activities related to a cloud computing service provider. Refer to the FFIEC's "Outsourced Cloud Computing" statement for more information.⁵⁶

II.C.20(b) *Managed Security Service Providers*

Management may rely on third parties to provide security services; management, however, remains responsible for ensuring the security of the institution's systems and information by overseeing the effectiveness of the services provided by the managed security services provider. Additional information is available in appendix D of the *IT Handbook's* "Outsourcing Technology Services" booklet.

II.C.21 Business Continuity Considerations

Action Summary

Management should do the following:

- Identify personnel who will have critical information security roles during a disaster, and train personnel in those roles.
- Define information security needs for backup sites and alternate communication networks.
- Establish and maintain policies that address the concepts of information security incident response and resilience, and test information security incident scenarios.

Business continuity plans should be reviewed as an integral part of the security process. Strategies should consider the different risk environments and the degree of risk mitigation necessary to protect the institution if continuity plans must be implemented. Management should train personnel regarding their security roles during a disaster. Additionally, management should update technologies and plans for backup sites and communications networks. These security considerations should be integrated with the testing of the business continuity plan.

Information security events may trigger activation of the business continuity plan. Therefore, the institution's plan should include steps that explicitly address information security incident response and resilience. Resilience testing should incorporate information security event scenarios identified by the institution.

Refer to the *IT Handbook's* "Business Continuity Planning" booklet for more information.

⁵⁶ See FFIEC, "[Outsourced Cloud Computing](#)," July 10, 2012.

II.C.22 Log Management

Network and host activities typically are recorded on the host and sent across the network to a central logging repository. The data that arrive at the repository are in the format of the software that recorded the activity. The logging repository may process the data and can enable timely and effective log analysis. Management should have effective log retention policies that address the significance of maintaining logs for incident response and analysis needs.

Log files are critical to the successful investigation and prosecution of security incidents and can potentially contain sensitive information. Intruders often attempt to conceal unauthorized access by editing or deleting log files. Therefore, institutions should strictly control and monitor access to log files whether on the host or in a centralized logging repository. Considerations for securing the integrity of log files include the following:

- Encrypting log files that contain sensitive data or that are transmitted over the network.
- Ensuring adequate storage capacity to avoid gaps in data gathering.
- Securing backup and disposal of log files.
- Logging the data to a separate, isolated computer.
- Logging the data to read-only media.
- Setting logging parameters to disallow any modification to previously written data.
- Restricting access to log files to a limited number of authorized users.

Additionally, logging practices should be reviewed periodically by an independent party to ensure appropriate log management.

Logs are voluminous and challenging to read. They come from a variety of systems and can be difficult to manage and correlate. Security information and event management (SIEM) systems can provide a method for management to collect, aggregate, analyze, and correlate information from discrete systems and applications. Management can use SIEM systems to discern trends and identify potential information security incidents. SIEM systems can be used to gather information from the following:

- Network and security devices and systems.⁵⁷
- Identity and access management applications.
- Vulnerability management and policy compliance tools.
- Operating system, database, and application logs.
- Physical and environmental monitoring systems.
- External threat data.

Regardless of the method of log management, management should develop processes to collect, aggregate, analyze, and correlate security information. Policies should define retention periods for security and operational logs. Institutions maintain event logs to understand an incident or cyber event after it occurs. Monitoring event logs for anomalies and relating that information

⁵⁷ These can include intrusion detection and prevention systems, DLP solutions, and firewalls.

with other sources of information broadens the institution's ability to understand trends, react to threats, and improve reports to management and the board.

II.D Risk Monitoring and Reporting

Risk monitoring is a process by which the institution tracks information about its inherent risk profile and identifies gaps in the effectiveness of risk mitigation activities. Risk monitoring should address changing threat conditions in both the institution and the greater financial industry. Threats change frequently, particularly in terms of the threat's capabilities and intentions, as well as the vulnerabilities they may exploit. Vulnerabilities in software are continually announced, and other vulnerabilities may emerge as the institution's systems are modified or updated. External requirements, including the use of new third-party service providers, also may change the institution's inherent risk profile.

Risk reporting is a process that produces information systems reports that address threats, capabilities, vulnerabilities, and inherent risk changes. Risk reporting should describe any information security events that the institution faces and the effectiveness of management's response and resilience to those events. The reporting process should provide a method of disseminating those reports to appropriate members of management. The contents of the reports should prompt action, if necessary, in a timely manner to maintain appropriate levels of risk.

II.D.1 Metrics

A mature and effective information security program uses metrics to improve the program's effectiveness and efficiency. Management should develop metrics that demonstrate the extent to which the security program is implemented and whether the program is effective. Metrics are used to measure security policy implementation, conformance with the information security program, the adequacy of security services delivery, and the impact of security events on business processes. The measurement of security characteristics can allow management to increase control and drive improvements to the security process. Metrics generally are formed to measure conformance to the standards and procedures that are used to implement policies.

Management should utilize metrics to quantify and report risks of the information security program. Metrics should be gathered from external sources and internal data. The scope of metrics should be comprehensive and commensurate with the complexity of the institution's operations. Reports should incorporate metrics tailored for different audiences and stakeholders. These metrics and other monitoring reports of the information security program should feed into ITRM reporting.

III Security Operations

Action Summary

Management should design policies and procedures to effectively manage security operations with the following characteristics:

- Broadly scoped to address all ongoing security-related functions.
- Guided by defined processes.
- Integrated with lines of business and third parties.
- Appropriately staffed and supplied with technology for continual incident detection and response activities.

Security operations involve a wide range of activities. Those activities may be centralized in a security operations center, distributed within the information security department and business lines, or outsourced in whole or in part. Security operations activities can include the following:

- Security software and device management (e.g., maintaining the signatures on signature-based devices and firewall rules).
- Forensics (e.g., analysis of potentially compromised systems).
- Threat identification and assessment.
- Vulnerability identification (e.g., operation or supervision of vulnerability scans, self-assessments, penetration tests, and analysis of audit results).
- Vulnerability cataloging and remediation tracking.
- Physical security management (e.g., CCTV, guards, and badge systems).
- Law enforcement interface (e.g., data retention and lawful intercepts).
- Third-party integration (e.g., managed security services and incident detection services).
- Network, host, and application activity monitoring.
- Analysis of threat intelligence from external sources.
- Engagement with information sharing groups.
- Incident detection and management.
- Enforcement of access controls.

Management should establish defined processes and appropriate governance to facilitate the performance of security operations. Policies should address the timing and extent of the security operations activities, reporting, escalation triggers, and response actions. Many institutions use an issue tracking system⁵⁸ to record and manage requests and events. An issue tracking system can be a source of evidence, contain a variety of security information, and serve as a valuable tool to assist management when taking actions to strengthen the information security environment.

⁵⁸ An issue tracking system (also ITS, trouble ticket system, ticketing management system, support ticket system, request management system, or incident ticket system) is a computer software package that manages and maintains lists of security issues.

Management should coordinate security operation activities with the institution's lines of business and with third-party service providers. Regardless of how extensive the coordination is, the goal should be to maintain a sufficient security operation capability across the entire environment.

Sufficient technology and staff should be available to support continual incident detection and response activities. Some institutions may rely on or supplement their activities with third parties to gain the necessary scope and depth of coverage. Refer to the *IT Handbook's* "Outsourcing Technology Services" booklet for more information.

III.A Threat Identification and Assessment

Action Summary

Management should do the following:

- Identify and assess threats.
- Use threat knowledge to drive risk assessment and response.
- Design policies to allow immediate and consequential threats to be dealt with expeditiously.

Threat identification and assessment involves discovering knowledge about threat sources and vulnerabilities and analyzing the potential for exploitation. This is much more focused than the risk identification process described in the "Risk Identification" section of this booklet.

Information gained from threat identification and assessment should be used in risk assessment and response to drive protective and detective strategies and tactics. Strategies involve the information security program's policies, standards, and procedures, and the implementing technologies. Examples of tactics include threat signatures used for incident identification and management of threat behaviors. NIST notes that types of threat sources include the following:

- Hostile cyber or physical attacks.
- Human errors of omission or commission.
- Structural failures of organization-controlled resources (e.g., hardware, software, and environmental controls).
- Natural and man-made disasters, accidents, and failures beyond the control of the organization.⁵⁹

Management should develop procedures for obtaining, monitoring, assessing, and responding to evolving threat and vulnerability information. The identification of threats involves the sources of threats, their capabilities, and their objectives. Information about threats generally comes from government (e.g., US-CERT), information-sharing organizations (e.g., FS-ISAC), industry sources, the institution, and third parties. Third-party information may be from organizations that specifically track and report on threats or from third-party reports of past activity. Some of those

⁵⁹ NIST SP 800-30, revision 1, "[Information Security: Guide for Conducting Risk Assessments](#)," September 2012.